

- A list of ongoing references to the CIS Controls in national and international standards, state and national legislation and regulation, trade and professional associations, etc.
- Information tailored for small and medium enterprises
- Measurement and metrics for the CIS Controls
- Pointers to vendor white papers and other materials that support the CIS Controls
- Documentation on alignment with the NIST® Cybersecurity Framework

How to Get Started



Historically, the CIS Controls were ordered in sequence to focus an enterprise's cybersecurity activities, with a subset of the first six CIS Controls referred to as "cyber hygiene." However, this proved to be too simplistic. Enterprises, especially small ones, could struggle with some of the early Safeguards and never get around to implementing later CIS Controls (for example, having a backup strategy to help recover from ransomware). As a result, starting with Version 7.1, we created CIS Controls **Implementation Groups (IGs)** as our recommended new guidance to prioritize implementation.

The CIS Controls IGs are self-assessed categories for enterprises. Each IG identifies a subset of the CIS Controls that the community has broadly assessed to be applicable for an enterprise with a similar risk profile and resources to strive to implement. These IGs represent a horizontal look across the CIS Controls tailored to different types of enterprises. Specifically, we have defined IG1 as "essential cyber hygiene," the foundational set of cyber defense Safeguards that every enterprise should apply to guard against the most common attacks (<https://www.cisecurity.org/controls/v8-1/>). Each IG then builds upon the previous one: IG2 includes IG1, and IG3 includes all CIS Safeguards in IG1 and IG2.

Using or Transitioning from Prior Versions of the CIS Controls

As the cyber threat landscape is continuously changing, we believe Version 8 and any updates are the best comprehensive controls we have ever produced. We also appreciate that enterprises who are actively using prior versions of the CIS Controls as a key part of their defensive strategy might be reluctant to move to Version 8. Our recommendation is that if you are using Version 7 or Version 7.1, you are following an effective and usable security plan, and over time you should consider moving to the latest iteration. If you are using Version 6 (or earlier), our recommendation is that you should start to plan a transition to Version 8 as soon as practicable.

For prior versions of the CIS Controls, we were able to provide only the simplest tools to aid in transition from prior versions, basically a spreadsheet-based change log. For Version 8, we have taken a much more holistic approach and worked with numerous partners to ensure that the CIS Controls ecosystem is ready to support your transition, <https://www.cisecurity.org/controls/v8-1/>.

Structure of the CIS Controls

The presentation of each Control in this document includes the following elements:

- **Overview.** A brief description of the intent of the Control and its utility as a defensive action
- **Why is this Control critical?** A description of the importance of this Control in blocking, mitigating, or identifying attacks, and an explanation of how attackers actively exploit the absence of this Control
- **Procedures and tools.** A more technical description of the processes and technologies that enable implementation and automation of this Control
- **Safeguard descriptions.** A table of the specific actions that enterprises should take to implement the Control

Implementation Groups



IG1

An IG1 enterprise is small to medium-sized with limited IT and cybersecurity expertise to dedicate toward protecting IT assets and personnel. The principal concern of these enterprises is to keep the business operational, as they have a limited tolerance for downtime. The sensitivity of the data that they are trying to protect is low and principally surrounds employee and financial information.

Safeguards selected for IG1 should be implementable with limited cybersecurity expertise and aimed to thwart general, non-targeted attacks. These Safeguards will also typically be designed to work in conjunction with small or home office commercial off-the-shelf (COTS) hardware and software.



IG2 (Includes IG1)

An IG2 enterprise employs individuals responsible for managing and protecting IT infrastructure. These enterprises support multiple departments with differing risk profiles based on job function and mission. Small enterprise units may have regulatory compliance burdens. IG2 enterprises often store and process sensitive client or enterprise information and can withstand short interruptions of service. A major concern is loss of public confidence if a breach occurs.

Safeguards selected for IG2 help security teams cope with increased operational complexity. Some Safeguards will depend on enterprise-grade technology and specialized expertise to properly install and configure.

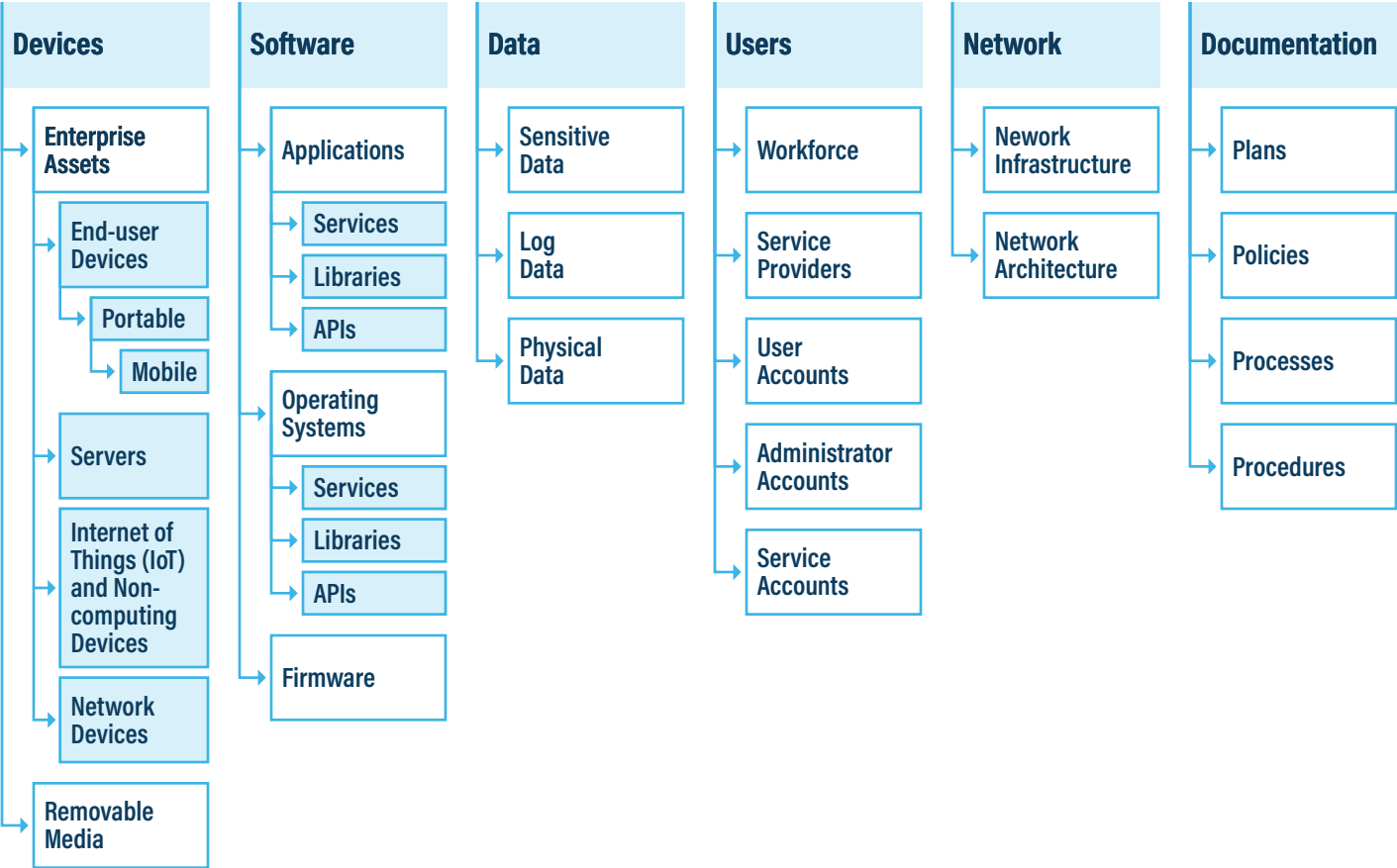


IG3 (Includes IG1 and IG2)

An IG3 enterprise employs security experts that specialize in the different facets of cybersecurity (e.g., risk management, penetration testing, application security). IG3 assets and data contain sensitive information or functions that are subject to regulatory and compliance oversight. An IG3 enterprise must address availability of services and the confidentiality and integrity of sensitive data. Successful attacks can cause significant harm to the public welfare.

Safeguards selected for IG3 must abate targeted attacks from a sophisticated adversary and reduce the impact of zero-day attacks.

Asset Classes



Devices

Devices are enterprise assets (data processing and storage assets), end-user devices, portable devices, mobile devices, servers, Internet of Things and non-computing devices, network devices, and removable media. Devices may exist in physical spaces, virtual infrastructure, or cloud-based environments. Devices can remotely connect to these systems.

- **Enterprise Assets:** Assets with the potential to store or process data. For the purpose of this document, enterprise assets include end-user devices, network devices, non-computing/Internet of Things (IoT) devices, and servers, in virtual, cloud-based, and physical environments.
- **End-user Devices:** Information technology (IT) assets used among members of an enterprise during work or off-hours. End-user devices include desktops and workstations, as well as portable and mobile devices such as laptops, smartphones, and tablets. For the purpose of this document, end-user devices are a subset of enterprise assets.

- **Portable Devices:** Transportable, end-user devices that have the capability to wirelessly connect to a network. Portable devices can include laptops which may require external hardware for connectivity and mobile devices, such as smartphones and tablets. For the purpose of this document, portable devices are a subset of end-user devices.
 - **Mobile Devices:** Small, enterprise-issued end-user devices with intrinsic wireless capability, such as smartphones and tablets. For the purpose of this document, mobile devices are a subset of portable devices.
- **Servers:** A device or system that provides resources, data, services, or programs to other devices on either a local area network or wide area network. Servers can provide resources and use them from another system at the same time. Servers can exist in datacenters, public/private/hybrid cloud environments, including temporal containers or serverless workloads. Examples of servers include web servers, application servers, mail servers, and file servers. For the purpose of this document, servers are a subset of enterprise assets.
- **Internet of Things (IoT) and Non-computing Devices:** Devices embedded with sensors, software, and other technologies. These devices may connect, store, and exchange data with other devices and systems. The device's connection to the internet can be intermittent, non-existent, or persistent. Examples of these devices include smart watches and other wearables, printers, smart screens, smart home devices, speakers, industrial control systems, and physical security sensors. For the purpose of this document, IoT and non-computing devices are a subset of enterprise assets.
- **Network Devices:** Electronic devices required for communication and interaction between devices on a computer network. Network devices include wireless access points, firewalls, physical/virtual gateways, routers, and switches. These devices consist of physical hardware, as well as virtual and cloud-based devices. For the purpose of this document, network devices are a subset of enterprise assets. Note that network devices are listed under Enterprise Assets because they are managed much like other devices, however, they also play a dual role in the Network Asset Class when related to the communication over a network.
- **Removable Media:** Any type of storage device that can be removed from a computer while the system is running and allows data to be moved from one system to another. Examples of removable media include CDs, DVDs, Blu-ray Discs, external hard drives, SD cards, tape backups, diskettes, and USB drives.

Software

Sets of data and instructions used to direct a computer to complete a specific task. Software assets include operating systems and applications. Both may contain services, libraries, or Application Programming Interfaces (APIs).

- **Applications:** A program, or a group of programs, running on top of an operating system hosted on an enterprise asset. Example application types include web, database, cloud-based, and mobile. Applications are considered a software asset in this document.
- **Operating Systems:** Software on enterprise assets that manages computer hardware and software resources and provides common services for programs. Example operating systems include Windows, Ubuntu, MacOS, Android, and z/OS. Operating systems are considered a software asset.
 - **Services:** Specialized programs that perform well-defined critical tasks for the operating system. Services often start with the operating system, run-in in the background, and can be stopped and started by users. Example services include managing network communications, users, file permissions, system security, and device interaction.
 - **Library:** A shareable pre-compiled codebase to include classes, procedures, scripts, configuration data, and more, used to develop software programs and applications. Libraries are designed to assist both the programmer and the programming language compiler in building and executing software more efficiently.
 - **Application Programming Interface (API):** A set of rules and interfaces for software components to interact with each other in a standardized way. APIs allow applications to access and communicate with both internal and external resources.
- **Firmware:** Software stored within a device's non-volatile memory, such as ROM or flash memory, used to allow different types of hardware to communicate with the operating system. Firmware is often updated outside of the enterprise's operating system and application software update process.

Data

A collection of facts that can be examined, considered, and used for decision-making. Although data may be physical, the CIS Controls primarily provide protection for digital data that may be stored, transferred, and processed by enterprise assets.

- **Sensitive Data:** Physical or digital data stored, processed, or managed by the enterprise that must be kept private, accurate, reliable, and available. If released or destroyed in an unauthorized manner, it would cause harm to the enterprise or its customers. These impacts may be due to a data breach or a violation of a policy, contract, or regulation.
- **Log Data:** A computer-generated data file that records the events occurring within the enterprise. Examples of logs include: operating system, anti-malware detection, database, application, network, firewall, web server, or access control logs (e.g., electronic locks, alarm system).
- **Physical Data:** Data that is stored in physical documents or stored on physical types of removable devices (e.g., USB drives, tape backups). Physical data may be sensitive or not.

Users

Employees, third-party vendors, contractors, service providers, consultants, or any other person who is authorized to access an enterprise asset. This also includes user, administrator, and service accounts.

- **Workforce:** All individuals who are employed or engaged by an organization and have access to its information systems, assets, or resources. It includes all employees both on-site and remote, excluding service providers and consultants.
- **Service Providers:** Entity that offers platforms, software, and services to other enterprises. Examples include IT consultants, managed service provider (MSPs), Software as a Service (SaaS) platforms, and cloud service providers. Third-party providers and vendors are also considered Service Providers. These services may be paid or free. Some relationships may or may not require a contract or SLA in place. Examples include data analysis, traffic blocking, and similar services.
- **User Accounts:** An identity comprised of a set of credentials (e.g., username, password) that defines a user on a computer or computing system. A user account keeps track of a user's information and settings, controls the files, folders, and resources a user is allowed to access, as well as the tasks a user is allowed to perform. For the purpose of this document, user accounts refer to "standard" user accounts with limited privileges and are used for general tasks.
- **Administrator Accounts:** Accounts for users requiring escalated privileges. The accounts are used for managing aspects of a computer, domain, or the whole enterprise information technology infrastructure. Each administrator account should be assigned to a single user. Common administrator account subtypes include root accounts, local administrator, domain administrator accounts, and network or security appliance administrator accounts.
- **Service Accounts:** A service account is created specifically to run applications, services, and automated tasks on an operating system. Service accounts may also be created just to own data and configuration files. Each service account should be used for a specific service or function, and it should have an assigned owner who is responsible for how the account is used. Service accounts should not be used for general purpose computing.

Network

A network is a group of interconnected devices that exchange data. Network is a superset of network infrastructure and network architecture.

- **Network Infrastructure:** The collection of network resources that provide connectivity, management, business operations, and communication. It consists of hardware and software, systems and devices, and it enables computing and communication between users, services, applications, and processes. Network infrastructure can be in the cloud, physical, or virtual.

- **Network Architecture:** Refers to how a network is designed, both physically and logically. It defines how a network is organized, including the connections between devices and software as well as the data that is transmitted between them. This should include network architecture diagrams and security architecture diagrams.

Documentation

Policies, processes, procedures, plans, diagrams, and other written material (e.g., compliance reports) either physical or digital. Examples include methods of governance for an enterprise, processes that users follow, or describe network architecture.

- **Plan:** A plan implements policies and may include groups of policies, processes, and procedures.
- **Policy:** A policy is an official governance statement that outlines specific objectives of an information security program.
- **Process:** A set of general tasks and activities to achieve a series of security-related goals.
- **Procedure:** A procedure is an ordered set of steps that must be followed to accomplish a specific task. It provides the approved way of performing an action in a specific technological and organizational environment.

CIS Critical Security Controls



CONTROL 1

Inventory and Control of Enterprise Assets

Safeguards: 5	IG1: 2/5	IG2: 4/5	IG3: 5/5
---------------	----------	----------	----------

Overview

Actively manage (inventory, track, and correct) all enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/Internet of Things (IoT) devices; and servers) connected to the infrastructure physically, virtually, remotely, and those within cloud environments, to accurately know the totality of assets that need to be monitored and protected within the enterprise. This will also support identifying unauthorized and unmanaged assets to remove or remediate.

Why is this Control critical?

Enterprises cannot defend what they do not know they have. Managed control of all enterprise assets also plays a critical role in security monitoring, incident response, system backup, and recovery. Enterprises should know what data is critical to them, and proper asset management will help identify those enterprise assets that hold or manage this critical data, so that appropriate security controls can be applied.

External attackers are continuously scanning the internet address space of target enterprises, premise-based or in the cloud, identifying possibly unprotected assets attached to an enterprise’s network. Attackers can take advantage of new assets that are installed, yet not securely configured and patched. Internally, unidentified assets can also have weak security configurations that can make them vulnerable to web- or email-based malware; and, adversaries can leverage weak security configurations for traversing the network, once they are inside.

Additional assets that connect to the enterprise’s network (e.g., demonstration systems, temporary test systems, guest networks) should be identified and/or isolated in order to prevent adversarial access from affecting the security of enterprise operations.

Large, complex, dynamic enterprises understandably struggle with the challenge of managing intricate, fast-changing environments. However, attackers have shown the ability, patience, and willingness to “inventory and control” our enterprise assets at very large scale in order to support their opportunities.